QUANTUM SECURITY INTELLIGENCE

Отчёт об аудите безопасности и постквантовой готовности

rustcrypto-rsa @ f96c4b5d629a · RustCrypto project — публичный репозиторий (пассивная проверка)

Организация	QSI
Дата отчёта	2026-10-28 12:51 UTC
Версия отчёта	1
Запуск аудита	1acd22ab-77cd-485d-86c8-d51734a5ccfe · Документальный аудит · 2026-10-28 12:51 UTC
Версия анализатора	qsi-engine 1.2.0
Профиль риска	Разработчик ПО безопасности
SHA-256 содержимого	`c0d439a694ce1e368fd2f36235910d4b8fb8e439d2c8ee8f0b7a317d4baa0ae1`
Ключ подписи (Ed25519, отпечаток SHA-256; подпись — отдельный файл report.sig.json)	`5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`

Содержание

1. Резюме для руководства
2. Область и границы проверки
3. Методология
4. Проверенные и непроверенные активы
5. Краткое описание архитектуры
6. Общая оценка состояния безопасности
7. Сводка находок по серьёзности
8. Подробное описание находок
9. Подтверждающие доказательства
10. Постквантовая оценка
11. Ограничения и допущения
12. План устранения проблем
13. Приоритеты на 30, 60 и 90 дней
14. Проверки после устранения
15. Использованные инструменты
16. Источники и нормативные документы
17. Приложения

Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.

Резюме для руководства

4	0	0	1	2
Всего находок	Критическая	Высокая	Средняя	Низкая

Классификация	Количество
Подтверждённая техническая уязвимость	0
Известная уязвимая версия компонента	2
Подтверждённая ошибка конфигурации	0
Потенциальный криптографический риск	0
Долгосрочный постквантовый риск	1
Рекомендация по улучшению	0
Недостаточность данных	1

Top 5

ID	Серьёзность	Подробное описание находок	Балл приоритета
QSI-2026-05056	Средняя	Квантово-уязвимый RSA: роль не определена (5 файл(ов)) предварительно	35.3
QSI-2026-05058	Низкая	crypto-bigint 0.7.5 затронут RUSTSEC-2026-0387 (без оценки серьёзности) предварительно	20.4
QSI-2026-05059	Низкая	ctutils 0.4.2 затронут RUSTSEC-2026-0385 (без оценки серьёзности) предварительно	20.4
QSI-2026-05057	Информационная	Не обнаружено криптобиблиотек с поддержкой PQC предварительно	13.5

Неравенство Моски (x + y > z): x = 10, y = 3, z = 8 → при этом сценарии миграция завершится слишком поздно. z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет. Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Область и границы проверки

Режим: Документальный аудит

Репозиторий: https://github.com/RustCrypto/RSA @ f96c4b5d629a0aeb6f680294debfd38ec8a81f68 — ссылки в доказательствах открывают строки на этом коммите.

Предоставленные входные данные

35 файлов, всего 300818 байт, редактирований: 5; список SHA-256 по файлам — в приложении C.

Методология

Аудит выполнен движком QSI 1.2.0. Каждый анализатор формирует факты (правило, параметры, доказательства); тексты находок генерируются из каталога правил. Источники методики указаны в разделе «Источники и нормативные документы».

Приоритизация: объяснимая взвешенная модель (серьёзность, вероятность эксплуатации, доступность атакующему, влияние на конфиденциальность/целостность/доступность с весами профиля «Разработчик ПО безопасности», критичность актива, срочность, простота устранения) с множителем уверенности. CVSS v3.1 применяется только к техническим уязвимостям с определённым вектором. Для долгосрочных квантовых рисков используется неравенство Моски; их серьёзность ограничена уровнем «Средняя», и они никогда не представляются как эксплуатируемые уязвимости.

Классификация находок: подтверждённая техническая уязвимость; известная уязвимая версия компонента (версия зависимости названа в бюллетене; затронутый код может не вызываться — это проверяется отдельно, а подтверждённая проверкой становится уязвимостью); подтверждённая ошибка конфигурации; потенциальный криптографический риск; долгосрочный постквантовый риск; рекомендация по улучшению; недостаточность данных. Находки на основе эвристик помечены как предварительные; решения аналитика показаны рядом с находками.

Покрытие проверок

Область	Статус	Количество	Примеры
dependencies	проверено	3	Cargo.lock: 120 dependencies parsed (120 pinned); Cargo.toml: 28 dependencies parsed (0 pinned); marvin-toolkit/Cargo.toml: 3 dependencies parsed (0 pinned)
source_code	проверено	32	src/algorithms/generate.rs: 187 lines scanned with 16 rule patterns and 122 registry patterns; 50 lines in #[cfg(test)] modules ignored; src/algorithms/mgf.rs: 78 lines scanned with 16 rule patterns and 122 registry patterns; src/algorithms/oaep.rs: 262 lines scanned with 16 rule patterns and 122 registry patterns
keys	ошибка (не проверено)	1	src/key.rs line 1134: public key could not be parsed (ValueError)
certificates_and_keys	проверено	5	src/key.rs: certificates/keys parsed; src/lib.rs: certificates/keys parsed; src/oaep.rs: certificates/keys parsed
keys	проверено	5	src/lib.rs: the key block at line 139 sits in a documentation comment, where it is the worked example of the crate's own API; src/oaep.rs: private key block at line 339 is test data (test code); src/pkcs1v15.rs: private key block at line 304 is test data (test code)
osv_advisories	проверено	1	120 pinned packages queried at OSV.dev; 2 affected

Длинные списки здесь сгруппированы; полный список по файлам — в JSON-версии отчёта, подписанной тем же ключом.

Проверенные и непроверенные активы

Предоставленные входные данные: 36 (входные файлы: C)

Не проверено

- keys: src/key.rs line 1134: public key could not be parsed (ValueError)

Краткое описание архитектуры

Static review of the source tree rustcrypto-rsa at f96c4b5d629a0aeb6f680294debfd38ec8a81f68. 35 files analysed; of 75 files, 23 are test, fuzzing, benchmark or example code and were left out, 17 are not read by any analyzer, 0 exceed the per-file limit and 0 did not fit the total limit. No requests were sent to the owner's systems.

Общая оценка состояния безопасности

98
Ориентировочный индекс состояния (0–100)

54.5%
Доля квантово-уязвимых элементов инвентаризации

11
Криптографическая инвентаризация

Рассчитан по находкам в области проверки (подтверждённые и потенциальные проблемы, взвешенные по серьёзности). Ориентировочный; не сравним между аудитами с разной областью.

Сводка находок по серьёзности



ID	Подробное описание находок	Классификация	Серьёзность	Уверенность
QSI-2026-05056	Квантово-уязвимый RSA: роль не определена (5 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно
QSI-2026-05058	crypto-bigint 0.7.5 затронут RUSTSEC-2026-0387 (без оценки серьёзности)	Известная уязвимая версия компонента	Низкая	Низкая, предварительно
QSI-2026-05059	ctutils 0.4.2 затронут RUSTSEC-2026-0385 (без оценки серьёзности)	Известная уязвимая версия компонента	Низкая	Низкая, предварительно
QSI-2026-05057	Не обнаружено криптобиблиотек с поддержкой PQC	Недостаточность данных	Информационная	Средняя, предварительно

Подробное описание находок

QSI-2026-05056 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый RSA: роль не определена (5 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

8 упоминаний RSA в 5 файл(ах), например src/encoding.rs:68. Роль по путям, именам функций и соседнему коду: роль не определена. По коду не видно, что защищают ключи; приоритет определит проверка.

Затронутый актив	source-code:RSA:general
Источник данных	src/encoding.rs
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.2.0 · 2026-10-28 12:51 UTC
Балл приоритета	35.3 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=3.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте src/encoding.rs:68 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · src/encoding.rs · line 68 · SHA-256 848496bd7c37c631… · Файл 39ec4b355f95e45b…

```
67 |
68 |         RsaPrivateKey::from_components(n, e, d, primes).map_err(|_| KeyMalformed)
69 |     }
```

file_excerpt · src/encoding.rs · line 88 · SHA-256 51040fadaa40d8ae… · Файл 39ec4b355f95e45b…

```
87 |
88 |         RsaPublicKey::new(n, e).map_err(|_| KeyMalformed)
89 |     }
```

file_excerpt · src/key.rs · line 338 · SHA-256 b400f8009b313e18… · Файл eeb1e8704e8643c0…

```
337 |         let components = generate_multi_prime_key_with_exp(rng, 2, bit_size, exp)?;
338 |         RsaPrivateKey::from_components(
339 |             components.n.get(),
```

file_excerpt · src/key.rs · line 364 · SHA-256 6202abba500461e1… · Файл eeb1e8704e8643c0…

```
363 |         let components = generate_multi_prime_key_with_exp(rng, 2, bit_size, exp)?;
364 |         RsaPrivateKey::from_components(
365 |             components.n.get(),
```

file_excerpt · src/pkcs1v15/signing_key.rs · line 60 · SHA-256 b0263c77cb240628… · Файл 8cdeedb6de0749c2…

```
59 |         Ok(Self {
60 |             inner: RsaPrivateKey::new(rng, bit_size)?,
61 |             prefix: pkcs1v15_generate_prefix::<D>(),
```

file_excerpt · src/pkcs1v15/signing_key.rs · line 89 · SHA-256 96efd77715170f81… · Файл 8cdeedb6de0749c2…

```
88 |         Ok(Self {
89 |             inner: RsaPrivateKey::new(rng, bit_size)?,
90 |             prefix: Vec::new(),
```

file_excerpt · src/pss/blinded_signing_key.rs · line 80 · SHA-256 129f3a710601ea4c… · Файл 05cb7d0e84ec7fcd…

```
79 |         Ok(Self {
80 |             inner: RsaPrivateKey::new(rng, bit_size)?,
81 |             salt_len,
```

file_excerpt · src/pss/signing_key.rs · line 85 · SHA-256 00c09dc98ca71977… · Файл 95cd495708093fa3…

```
84 |         Ok(Self {
85 |             inner: RsaPrivateKey::new(rng, bit_size)?,
86 |             salt_len,
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-05058 · DEP-ADVISORY-UNRATED

Низкая

crypto-bigint 0.7.5 затронут RUSTSEC-2026-0387 (без оценки серьёзности)

Известная уязвимая версия компонента · Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает RUSTSEC-2026-0387 для пакета crates.io crypto-bigint версии 0.7.5: Multiple timing variability issues in operations intended to be constant-time. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку

«предварительно» до разбора. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:crates.io/crypto-bigint@0.7.5
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 12:51 UTC
Балл приоритета	20.4 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/RUSTSEC-2026-0387
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev RUSTSEC-2026-0387 · manifest · SHA-256 90c1f0cc3ccb6bb6...


```
{"id": "RUSTSEC-2026-0387", "aliases": [], "modified": "2026-10-24T03:45:02.365137418Z", "summary":
"Multiple timing variability issues in operations intended to be constant-time", "severity": null,
"declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.7.6).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory RUSTSEC-2026-0387

QSI-2026-05059 · DEP-ADVISORY-UNRATED

Низкая

ctutils 0.4.2 затронут RUSTSEC-2026-0385 (без оценки серьёзности)

Известная уязвимая версия компонента · Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает RUSTSEC-2026-0385 для пакета crates.io ctutils версии 0.4.2: Non-constant-time mask generation and `u128` comparisons. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:crates.io/ctutils@0.4.2

Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.2.0 · 2026-10-28 12:51 UTC
Балл приоритета	20.4 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/RUSTSEC-2026-0385
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev RUSTSEC-2026-0385 · manifest · SHA-256 200470326c8a5ad1...


```
{"id": "RUSTSEC-2026-0385", "aliases": [], "modified": "2026-10-23T08:30:02.389575143Z", "summary":
"Non-constant-time mask generation and `u128` comparisons", "severity": null,
"declared_in_manifest": false}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.4.4).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory RUSTSEC-2026-0385

QSI-2026-05057 · DEP-NO-PQC-LIBRARY

Информационная

Не обнаружено криптобиблиотек с поддержкой PQC

Недостаточность данных | Уверенность: Средняя | предварительно — требует дополнительной проверки

В 3 манифестах зависимостей QSI нашёл криптобиблиотеки (rsa), но ни одной из списка поддерживающих PQC.

Затронутый актив	dependencies
Источник данных	dependency manifests
Метод обнаружения	Сопоставление названий зависимостей.
Анализатор	dependencies 1.2.0 · 2026-10-28 12:51 UTC
Балл приоритета	13.5 / 100 (Разработчик ПО безопасности)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Только индикатор готовности: поддержка PQC может обеспечиваться платформой (OpenSSL, ОС, облачный KMS), а не зависимостями приложения.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Изучите перечисленные в доказательстве манифесты.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

dependency · Cargo.lock, Cargo.toml, marvin-toolkit/Cargo.toml · SHA-256 bceb41c8a05bf530…

```
Crypto libraries: rsa
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Отсутствие доказательств не является доказательством отсутствия: системные библиотеки и транзитивные зависимости могут не указываться.

РЕКОМЕНДАЦИЯ

Определите источник поддержки PQC (TLS-терминатор, KMS/HSM, обновление библиотек).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование после обновлений.

FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM); FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA)

Подтверждающие доказательства

ID	Тип	Источник данных	SHA-256
QSI-2026-05056	file_excerpt	src/encoding.rs (line 68)	848496bd7c37c63103d96a76766750a0c93994941a9810bfd3804b1d855e2
QSI-2026-05056	file_excerpt	src/encoding.rs (line 88)	51040fadaa40d8aefffe667c170da4266984b8003fe2220dcf044ffd55ab4
QSI-2026-05056	file_excerpt	src/key.rs (line 338)	b400f8009b313e186171f142d7584b0f639b5a05524e78b44461a94f2104c
QSI-2026-05056	file_excerpt	src/key.rs (line 364)	6202abba500461e188a8f64092e4524b2f6dfb3202a0694dc57bad41e0fe4
QSI-2026-05056	file_excerpt	src/pkcs1v15/signing_key.rs (line 60)	b0263c77cb240628bb2f31d489438c088a47a65609d04db1b81f99208ac3c
QSI-2026-05056	file_excerpt	src/pkcs1v15/signing_key.rs (line 89)	96efd77715170f81d71a18c7c23d8db777764f09d7bfbc345825c9e3cf46a
QSI-2026-05056	file_excerpt	src/pss/blinded_signing_key.rs (line 80)	129f3a710601ea4cfcdb8113049c8c1f093d9e451247404aac20c41f11d9c
QSI-2026-05056	file_excerpt	src/pss/signing_key.rs (line 85)	00c09dc98ca719774e6d1850f1e06364da42e2119ba5c17415b5e09cb961a
QSI-2026-05058	tool_output	OSV.dev RUSTSEC-2026-0387 (manifest)	90c1f0cc3ccb6bb642d968797b426e8af0e7976cb2c08c7f8deb3d57ddb78
QSI-2026-05059	tool_output	OSV.dev RUSTSEC-2026-0385 (manifest)	200470326c8a5ad19deb3639dff41d33749b1153097b6b87ef95e4beec747
QSI-2026-05057	dependency	Cargo.lock, Cargo.toml, marvin-toolkit/Cargo.toml	bceb41c8a05bf5308ccf41f3394d1edb11551672e62af9fdef4204d525b69

Постквантовая оценка

	Обмен ключами (x — сколько данные должны оставаться конфиденциальными; «собери сейчас, расшифруй потом»)	Подписи (x — сколько подписи и ключи должны оставаться доверенными)
Срок жизни данных/ключей x	10	5
Время миграции y	3	3
Принятое число лет до CRQC z	8 (early)	8
x + y − z	5 → при этом сценарии миграция завершится слишком поздно	0 → запас минимален

Допущения планирования: x для обмена ключами, x для подписей, y — значения по умолчанию профиля риска «Разработчик ПО безопасности», а не данные клиента; с фактическими сроками клиента вывод может измениться.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Уровни: 0 — нет; 1 — есть, но не подключено; 2 — используется вне критичных путей; 3 — гибрид в критичном пути; 4 — постквантовое по умолчанию в критичных путях (корень доверия, обёртка ключей, обмен ключами в канале). Оценка по коду и манифестам.

Что делают квантово-уязвимые алгоритмы

Роль	Алгоритмы (файлы)	ID	Первый шаг
роль не определена	RSA (5)	QSI-2026-05056	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости

Роль определяется по путям файлов, именам функций и коду вокруг совпадений; проверка её подтверждает. Сначала — ключи корня доверия и обёрнутые ключи: их трудно заменить или можно записать уже сегодня.

z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Квантовый статус	Количество
сниженный запас (Гровер), одобрен	2
Гровер: допустимо по NIST, ниже рекомендаций ECCG/ANSSI	2
н/п	1
уязвим (Шор)	6

Подробное описание находок: QSI-2026-05056

Анкета постквантовой готовности

Анкета готовности для проекта не заполнялась.

Квантовые алгоритмы, значимые для этой инвентаризации

Квантовый алгоритм	Действие	Алгоритмы из инвентаризации (строк)	Что это значит для аудита
Алгоритм Шора — факторизация Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	RSA (6)	Взламывает RSA при любой длине ключа: более длинный модуль лишь полиномиально повышает стоимость. Планируйте переход на ML-KEM (или гибрид) для установления ключей и ML-DSA / SLH-DSA для подписей; начинайте с ключей, защищающих данные, которые должны оставаться конфиденциальными годами («собери сейчас — расшифруй потом»), и с долгоживущих подписей.
Алгоритм Гровера — поиск ключа и прообразов Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	SHA-2 (4)	Не взлом. Ключи 256 бит (AES-256, ChaCha20) сохраняют хороший запас; AES-128 соответствует категории 1 NIST, но некоторые регуляторы требуют 256-битных ключей в квантово-устойчивых системах (см. запись AES-128). Для долгоживущих данных предпочитайте 256-битные ключи; 256-битные хеши для стойкости к прообразам менять не нужно.
Брассар–Хойер–Тапп — поиск коллизий Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	SHA-2 (4)	256-битные хеши (SHA-256, SHA3-256) остаются достаточными по стойкости к коллизиям; 160-битные хеши слабы уже классически (коллизии SHA-1 практичны). Где нужны категории NIST 4–5, используйте хеши на 384/512 бит.

Действие: взламывает — алгоритм нужно заменить; ослабляет — более длинные ключи или выходы восстанавливают запас; учтено в стандартных параметрах — при стандартных наборах действий не требуется; только при суперпозиционных запросах — к обычному применению неприменимо.

Ограничения и допущения

- Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.
- z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.
- keys — ошибка (не проверено): src/key.rs line 1134: public key could not be parsed (ValueError)

План устранения проблем

QSI-2026-05058 · P3 · 60 дн. устранение первопричины

Разберите RUSTSEC-2026-0387; при необходимости обновите crypto-bigint до исправленной версии (0.7.6).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает RUSTSEC-2026-0387 или результат разбора записан.

QSI-2026-05059 · P3 · 60 дн. устранение первопричины

Разберите RUSTSEC-2026-0385; при необходимости обновите ctutils до исправленной версии (0.4.4).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает RUSTSEC-2026-0385 или результат разбора записан.

QSI-2026-05056 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования RSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	

	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-05056 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию RSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема или гибридной схемы.

Приоритеты на 30, 60 и 90 дней

30 дн.

Приоритет	ID	Действие	Тип
Нет			

60 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-05058	Разберите RUSTSEC-2026-0387; при необходимости обновите crypto-bigint до исправленной версии (0.7.6).	устранение первопричины
P3	QSI-2026-05059	Разберите RUSTSEC-2026-0385; при необходимости обновите ctutils до исправленной версии (0.4.4).	устранение первопричины

90 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-05056	Внесите использования RSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P4	QSI-2026-05056	Запланируйте миграцию RSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины

Проверки после устранения

ID	Повторная проверка
QSI-2026-05056	Повторите инвентаризацию после рефакторинга.
QSI-2026-05058	Повторите сканирование зависимостей после обновления.
QSI-2026-05059	Повторите сканирование зависимостей после обновления.
QSI-2026-05057	Повторите сканирование после обновлений.

Использованные инструменты

Tool	Version
blockchain	1.0.0
certificates	1.1.0
chain_map	1.0.0
configs	1.1.0
dependencies	1.2.0
inventory_document	1.1.0
solidity	1.2.0
source_code	1.3.0
tls_code	1.1.0
tls_live	1.0.0
qsi-engine	1.2.0
OSV.dev API	v1

Источники и нормативные документы

Reviewed: 2026-10-13

1. A. Chailloux, M. Naya-Plasencia, A. Schrottenloher — An Efficient Quantum Collision Search Algorithm and Implications on Symmetric Cryptography (ASIACRYPT 2017; IACR ePrint 2017/847) — IACR ePrint. https://eprint.iacr.org/2017/847 (peer-reviewed article: Õ(2^{2n/5}) time, O(n) qubits, Õ(2^{n/5}) classical memory)
2. C. Gidney — How to factor 2048 bit RSA integers with less than a million noisy qubits (arXiv:2505.15917) — arXiv. https://arxiv.org/abs/2505.15917 (preprint (2025-05-21): < 1 million noisy qubits, < 1 week, 0.1% gate error, 1 µs surface-code cycle)
3. C. Gidney, M. Ekerå — How to factor 2048 bit RSA integers in 8 hours using 20 million noisy qubits (Quantum 5, 433) — Quantum. https://doi.org/10.22331/q-2021-04-15-433 (peer-reviewed article (2021): 10^-3 gate error, 1 µs cycle, 10 µs reaction time)
4. C. Zalka — Grover's quantum searching algorithm is optimal (Phys. Rev. A 60, 2746, 1999; arXiv:quant-ph/9711070) — APS. https://doi.org/10.1103/PhysRevA.60.2746 (peer-reviewed article: optimal for any success probability; parallel search gains no more than splitting the space)
5. Common Vulnerability Scoring System v3.1: Specification Document — FIRST. https://www.first.org/cvss/v3.1/specification-document (final)
6. D. J. Bernstein — Cost analysis of hash collisions: Will quantum computers make SHARCS obsolete? (2009) — cr.yp.to. https://cr.yp.to/hash/collisioncost-20090823.pdf (paper dated 2009-08-23)
7. FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM) — NIST. https://csrc.nist.gov/pubs/fips/203/final (final (August 2024))
8. FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA) — NIST. https://csrc.nist.gov/pubs/fips/204/final (final (August 2024))
9. FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA) — NIST. https://csrc.nist.gov/pubs/fips/205/final (final (August 2024))
10. G. Brassard, P. Høyer, A. Tapp — Quantum Algorithm for the Collision Problem (LATIN '98; arXiv:quant-ph/9705002) — Springer / arXiv. https://arxiv.org/abs/quant-ph/9705002 (peer-reviewed article: collisions of r-to-one functions in O((N/r)^{1/3}) expected evaluations)
11. L. K. Grover — A fast quantum mechanical algorithm for database search (STOC 1996) — ACM. https://doi.org/10.1145/237814.237866 (peer-reviewed article)
12. M. Amy et al. — Estimating the cost of generic quantum pre-image attacks on SHA-2 and SHA-3 (SAC 2016; arXiv:1603.09383) — Springer / arXiv. https://arxiv.org/abs/1603.09383 (peer-reviewed article: SHA-256 about 2^153.8 surface-code cycles on 2^12.6 logical qubits; SHA3-256 about 2^146.5 cycles on 2^20)
13. M. Cain et al. — Shor's algorithm is possible with as few as 10,000 reconfigurable atomic qubits (arXiv:2603.28627) — arXiv. https://arxiv.org/abs/2603.28627 (preprint (2026-03-30): P-256 in a few days with 26,000 physical neutral-atom qubits; RSA-2048 one to two orders of magnitude longer)
14. M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018) — IEEE. https://doi.org/10.1109/MSP.2018.3761723 (peer-reviewed article; source of the x + y > z migration inequality)
15. NIST IR 8547 — Transition to Post-Quantum Cryptography Standards — NIST. https://csrc.nist.gov/pubs/ir/8547/ipd (initial public draft (November 2024); proposes deprecating quantum-vulnerable public-key algorithms after 2030 and disallowing them after 2035 — dates may change in the final version)
16. NIST — Post-Quantum Cryptography Standardization: Evaluation Criteria, Security (Call for Proposals, Section 4.A.5) — NIST. https://csrc.nist.gov/Projects/Post-Quantum-Cryptography/Post-Quantum-Cryptography-Standardization/Evaluation-Criteria/Security-(Evaluation-Criteria) (security categories: AES-128 key search 2^170/MAXDEPTH quantum gates, AES-192 2^233/MAXDEPTH, AES-256 2^298/MAXDEPTH; MAXDEPTH 2^40–2^96)
17. OSV advisory RUSTSEC-2026-0385 — OSV.dev. https://osv.dev/vulnerability/RUSTSEC-2026-0385 (modified 2026-10-23T08:30:02.389575143Z)
18. OSV advisory RUSTSEC-2026-0387 — OSV.dev. https://osv.dev/vulnerability/RUSTSEC-2026-0387 (modified 2026-10-24T03:45:02.365137418Z)
19. P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997) — SIAM. https://doi.org/10.1137/S0097539795293172 (peer-reviewed article)
20. S. Jaques, M. Naehrig, M. Roetteler, F. Virdia — Implementing Grover oracles for quantum key search on AES and LowMC (EUROCRYPT 2020; arXiv:1910.01700) — Springer / arXiv. https://arxiv.org/abs/1910.01700 (peer-reviewed article: lower cost estimates for the AES key searches that define the NIST categories)

Приложения

A. Криптографическая инвентаризация

Алгоритм	Параметр	Расположение	Квантовый статус	Классический статус
SHA-2	SHA-384	src/pkcs1v15.rs:267	сниженный запас (Гровер), одобрен	допустимо
SHA-2	SHA-512	src/pkcs1v15.rs:272	сниженный запас (Гровер), одобрен	допустимо
SHA-2	SHA-224	src/pkcs1v15.rs:257	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ANSSI	устаревающий
SHA-2	SHA-256	src/pkcs1v15.rs:262	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ANSSI	допустимо
Crypto library rsa (RustCrypto rsa)	0.9	marvin-toolkit/Cargo.toml	н/п	допустимо
RSA		src/algorithms/rsa.rs	уязвим (Шор)	допустимо
RSA		src/encoding.rs:68	уязвим (Шор)	допустимо
RSA		src/key.rs:338	уязвим (Шор)	допустимо
RSA		src/pkcs1v15/signing_key.rs:60	уязвим (Шор)	допустимо
RSA		src/pss/blinded_signing_key.rs:80	уязвим (Шор)	допустимо
RSA		src/pss/signing_key.rs:85	уязвим (Шор)	допустимо

B. JSON

qsi.report/1 · SHA-256 c0d439a694ce1e368fd2f36235910d4b8fb8e439d2c8ee8f0b7a317d4baa0ae1

C. Входные файлы

Файл	Размер	SHA-256	Маскирования
Cargo.lock	28075	`be3f101d792bbf2d833588100d067b54a3b53ea3a5a41461a696cd7cedb95fc8`	0
Cargo.toml	3861	`23b63ed294721e4771e71976af4f7306040807589ebbcb338c36eb56d1f66e20`	0
marvin-toolkit/Cargo.toml	349	`cb34ab4bd9ebd619db29da7dda6c1f48485836d15e8726673ba77ecc0c096bd4`	0
src/algorithms/generate.rs	6418	`9d4cf485bac61795cf5c96b78fea6af45ba842ea4d574dad5a4b7274191bd7d7`	0
src/algorithms/mgf.rs	2099	`7b337420ea5a96d9b0805e83725f6d7a7a585f03f210fcb46335c9f32ba57dd2`	0
src/algorithms/oaep.rs	7712	`f1b4e5f78672699465f4b91754b3cf1edd10521875c086000b0c67e27bb1fa01`	0

src/algorithms/pad.rs	6901	ec20420686a242a804254cb9abd721c0a9339d1974ea6bbcbe9cfff806db2d55	0
src/algorithms/pkcs1v15.rs	9714	ffb0687c4a3a1e905dc2a59a2d70ad9ed7a82194a33277fb44a3cfa41c7d1ca4	0
src/algorithms/pss.rs	12066	e93c2e09331a441b711424675f8bc082dca18a296884b4ede067b2fb2f04f346	0
src/algorithms/rsa.rs	20225	6a455b19f5e3e25d4bdf70ec67c41678d8017fb192cb450347037cdd981ca6e8	0
src/algorithms.rs	968	d0849f47ed22ea07afb79e8cf4f1bfa6351a47f373cdb9c0d475fe33a4d4de62	0
src/dummy_rng.rs	608	aee7479544785b17942fd4800b5be942ab6313de28d9ee4f94bedd0b1f93900e	0
src/encoding.rs	8547	39ec4b355f95e45bf6822d9b4a9ab1d43d1c4b730b3c54dd5db993e8f222213e	0
src/errors.rs	3964	59eefe23b283cbdce1a2475a28be787cfe4c22aad8573adff0bc928e9dba2d3a	0
src/hazmat.rs	728	34143d40260f8da56f15d2e890acada46f02ca364dda52a1f8655643461da5f4	0
src/key.rs	51894	eeb1e8704e8643c049561837a8da28d4528513f23642f1ee3199201519049527	0
src/lib.rs	4832	b595e73a382c529d557c7ef2930828893be0d87a2f27936db5c636e06eae5728	1
src/oaep/decrypting_key.rs	3889	f9db7a3f0ec97476a1fe8ff6bceb53cf6d35bc19d82b09da91ec775cae323be9	0
src/oaep/encrypting_key.rs	3247	bb3e1352f26a56d32f0fe8ddefd54bd27bc3f5038ee4cf0609c2f0c353f6b648	0
src/oaep.rs	22195	d33b87a40ebbc0cd87b9d08f4c7d7195e1a109a8136b232c035afd22f98f63cf	1
src/pkcs1v15/decrypting_key.rs	2502	73da01e7ce18211e64f009408dfe27298377324518378ac4a0f41eb24b161258	0
src/pkcs1v15/encrypting_key.rs	1840	9dbe51d300b4026a8a97d861951bba43814c1d2aaa605b9f358e181faefcd771	0
src/pkcs1v15/signature.rs	2804	63a6870f765ac243f4c4f783596e42221bfae495406cba59dd33bf093d87c73d	0
src/pkcs1v15/signing_key.rs	9365	8cdeedb6de0749c22bd6e0bf0c07270b3bed15dde1d5c1477950579a20bbe2bf	0
src/pkcs1v15/verifying_key.rs	6643	c943c41c048c3cb0dab70bfc15b50c680577a0752cd71166197d044e33e9c781	0
src/pkcs1v15.rs	24525	560937820974e813a41eb96d0bbe49c6f4cebf838ad0795932945244edb6ebb5	1
src/pss/blinded_signing_key.rs	8466	05cb7d0e84ec7fcd64c5f091828214908d202cf47d6ca2b54c0e508c77c46cb6	0
src/pss/signature.rs	2780	543d2554a49c39b3325b6bc0493197ec9fe2c33b5ded180754b04065e48ed1fa	0
src/pss/signing_key.rs	9085	95cd495708093fa3747eda26bf0e0009e48f5a2feb46cf0c2a94203e2f2fe52f	0
src/pss/verifying_key.rs	6658	e023a2216d8e6acfb9ae104e325e7f5cd9fad1e7dbc3261e9eb2ea4dfe5cf7e2	0
src/pss.rs	21764	88537e9df026e7c4a3d343c6cd1d4dbfa4d34e035e10c411b8745f64b068f40e	2
src/traits/encryption.rs	1271	595a850d43cbf636953b4bded972558f8ee74882123e0b19128d0449c10778e2	0

src/traits/keys.rs	2908	b2d0fd9f8cc187b3fd9f96fb5c4251ee37daeabe7af6a8f37cf72c0870f4e588	0
src/traits/padding.rs	1634	1e524d6c95b7502918c32a7ca77bd83dbda1f458ba9c4976ea8a4c27ad0e105a	0
src/traits.rs	281	fdf9a94e6dc1bfe6881aa16075d05428e62ac7071a5d48127c566ddb609932f2	0